Quiz — Identity depth

Fillable quiz — type answers in the fields. Blank copies are already under `my-work/quizzes/`; answer them in place. Answer keys are not included.

1. Why do enterprises still run **SAML** beside **OIDC** — what fails if you assume every app speaks OIDC tokens?

2. Why do non-SSO apps still exist in large orgs, and what identity control fills the gap?

3. Why is a device certificate *not* the same as a passkey — what different question does each answer?

4. Why can a password-manager risk be severe even when “AES is fine” — name one non-crypto failure mode.

5. Scenario: The OAuth `state` parameter is omitted. Which attack becomes easier, and why does `state` exist?

6. Spot the bug: redirect_uri allow-list uses prefix match on `https://app.example` and accepts `https://app.example.evil.com`. Fix, and why exact match?

7. Why / how (RFC 10017): Why prefer a Backend-for-Frontend (BFF) with HTTP-only cookies over storing access tokens in the SPA's `localStorage`, and what CSRF control still matters after you move tokens server-side?